

[Logo Aeroportul Internațional Iași]

Platforma Alexandrit: descriere, securitate și găzduire

Prezentarea platformei și a serviciilor afiliate, nivelul de securitate și comparația cu un server intern

Document pregătit pentru Aeroportul Internațional Iași

Pregătit de: echipa platformei Alexandrit

Octombrie 2026

1. Rezumat

Platforma Alexandrit rulează astăzi pe furnizori cloud specializați: Vercel pentru aplicație, Supabase pentru baza de date, autentificare și fișiere, iar plățile trec prin procesatori certificați PCI DSS. Acest document explică cât de securizată este această infrastructură și o compară cu varianta mutării pe un server intern al aeroportului.

Recomandare

Platforma să rămână pe infrastructura cloud actuală, cu datele în Uniunea Europeană.

Aeroportul primește în plus o copie de siguranță zilnică a bazei de date pe un server propriu. Astfel are controlul asupra datelor fără să preia costul și riscul operării unui server public.

Pe scurt: certificările auditate extern pe care le au furnizorii actuali (SOC 2 Type 2, ISO 27001) ar fi greu de obținut pentru un server intern. Protecția automată la atacuri (DDoS, firewall web) și actualizările de securitate continue vin incluse. Un server intern oferă control fizic deplin asupra datelor, dar mută asupra aeroportului toată responsabilitatea: actualizări, monitorizare 24/7, copii de siguranță, recuperare după incident și personal specializat.

2. Ce este platforma Alexandrit

Alexandrit este o platformă online (SaaS) pentru organizații neguvernamentale. Fiecare ONG își face cont și primește, pe bază de abonament lunar, un CRM complet și un set de instrumente de strângere de fonduri. Organizațiile sunt complet separate între ele: fiecare vede doar propriile date.

Module principale

Modul	Ce face
CRM donatori	Evidența persoanelor fizice și a donațiilor, istoric, segmentare RFM, comunicare și automatizări.
Formularul 230	Formular online pentru redirectionarea a 3,5% din impozit, cu semnătură olografă pe ecran, generare PDF și borderou. CNP-urile sunt criptate.
Companii și sponsorizări	CRM pentru persoane juridice, prospectare, contracte de sponsorizare, declarația D177, verificarea CIF la ANAF.
Strângere de fonduri	Pagini publice de campanie cu donații online prin contul Stripe propriu al fiecărui ONG, actualizări pentru donatori.
Beneficiari și proiecte	Evidența beneficiarilor, a proiectelor și a fondurilor, portal pentru beneficiari.
Presă și comunicare	Comunicate de presă, contacte media, grupuri locale, newslettere pentru persoane fizice și companii.
Rapoarte	Rapoarte de activitate pentru companii, one-pager, rapoarte generate cu ajutorul inteligenței artificiale.
Echipă și KPI	Program de lucru, obiective și indicatori pe angajați, check-in săptămânal, task-uri, voluntari.
Instrumente auxiliare	Apeluri telefonice din browser, semnătură digitală a documentelor, bannere și SMS, consultanță programată.
Abonamente	Pachete lunare plătite prin Netopia, facturare automată prin Oblio.

3. Infrastructura și serviciile afiliate

Platforma folosește furnizori specializați pentru fiecare funcție. Mai jos sunt toți furnizorii și datele la care au acces.

Infrastructura de bază

Componentă	Furnizor	Rol
Aplicația web	Vercel	Rulează aplicația (Next.js). Funcțiile de server sunt în regiunea Dublin, în UE. Livrare prin rețea globală, cu HTTPS obligatoriu.
Baza de date	Supabase (PostgreSQL)	Datele organizațiilor, cu izolare strictă între clienți la nivelul bazei de date.
Autentificare	Supabase Auth	Conturi, parole stocate doar ca hash, login cu Google, resetare parolă.
Fișiere	Supabase Storage	Documente și imagini încărcate, cu reguli de acces pe fiecare organizație.
Cod sursă	GitHub	Istoric complet al modificărilor, verificări automate la fiecare schimbare.

Servicii afiliate

Serviciu	Pentru ce îl folosim	Date și securitate
Stripe	Donățiile online de pe paginile ONG-urilor, în contul Stripe al fiecărui ONG	Datele de card nu ajung la platformă. Certificat PCI DSS Level 1.
Netopia Payments	Plata abonamentelor platformei	Procesator român certificat PCI DSS. Plata se face pe pagina securizată Netopia.
Oblio	Emiterea facturilor pentru abonamente, cu transmitere e-Factura	Furnizor român de facturare. Primește doar datele de facturare.
ANAF (API public)	Verificarea CIF-ului la înscrisere și la adăugarea companiilor	Serviciu public al statului. Se trimite doar CIF-ul.
Resend / SMTP propriu	Emailuri de autentificare, invitații, chitanțe, newslettere	Emailurile de autentificare pleacă din regiunea UE (Irlanda).
Twilio	Apeluri telefonice din browser, din CRM (opțional)	Destinațiile sunt limitate la România, pentru protecția contului.
BoldSign	Semnătură digitală a contractelor (opțional)	Folosit doar pentru documentele trimise la semnat.
Canva	Design pentru rapoarte (opțional)	Conectare cu contul Canva al ONG-ului, prin autorizare OAuth.
Anthropic (Claude)	Generare de conținut, extragere din documente financiare, rapoarte	Datele trimise prin API nu sunt folosite la antrenarea modelelor. Utilizarea este limitată zilnic pe organizație.
Sentry	Monitorizarea erorilor aplicației	Proiect pe regiunea UE. Date personale eliminate din adrese înainte de trimitere.
Google Analytics 4	Statistici de vizitare a paginilor publice	Pornește doar după acordul vizitatorului. Exclus de pe paginile cu date personale.
Calendly	Programarea sesiunilor de consultanță	Afișat doar pe pagina de consultanță.

Toți furnizorii sunt menționați în Politica de confidențialitate și în acordul de prelucrare a datelor (DPA) al platformei.

4. Cât de securizați sunt furnizorii principali

Vercel (aplicația)

- **SOC 2 Type 2** pentru securitate, confidențialitate și disponibilitate. Raportul este emis anual de un auditor independent.
- **ISO/IEC 27001:2022** certificat, cu audit realizat de Schellman.
- **GDPR:** contract de prelucrare a datelor (DPA). Vercel este certificat în cadrul EU-U.S. Data Privacy Framework.
- **Protecție inclusă:** atenuarea automată a atacurilor DDoS, firewall web (WAF) și certificate HTTPS gestionate automat. Infrastructura de bază (AWS) este la rândul ei certificată ISO 27001 și SOC 2.
- **Teste de penetrare** realizate periodic de terți, conform DPA-ului Vercel.

Supabase (baza de date, autentificare, fișiere)

- **SOC 2 Type 2** și conformitate HIPAA, standardul american pentru date medicale. HIPAA presupune un acord BAA pe planurile Team sau Enterprise.
- **Criptare:** toate datele sunt criptate la stocare cu AES-256 și în tranzit cu TLS.
- **Copii de siguranță** zilnice automate. Opțional, se poate activa restaurarea la orice moment din trecut (Point-in-Time Recovery).
- **Regiune aleasă de client:** datele pot rămâne în UE, de exemplu în Irlanda sau Germania.

Procesatorii de plăți

- **Stripe:** PCI DSS Level 1, cel mai înalt nivel de certificare din industria plăților.
- **Netopia Payments:** procesator certificat PCI DSS. Plățile cu cardul se fac pe pagina securizată a procesatorului.

Surse: vercel.com/docs/security/compliance; vercel.com/legal/dpa; supabase.com/security. Pentru verificarea formală, rapoartele de audit SOC 2 se obțin direct de la furnizori.

5. Măsuri de securitate în aplicație

Pe lângă ce oferă furnizorii, aplicația are propriile straturi de protecție:

- **Izolare între organizații în baza de date:** regulile Row Level Security sunt active și impuse pe toate tabelele. Aplicația folosește un cont de bază de date care nu le poate ocoli, așa că o organizație nu poate vedea datele alteia nici în cazul unei erori în cod.
- **Criptarea datelor sensibile:** cheile de plată ale organizațiilor și CNP-urile sunt criptate cu AES-256-GCM înainte de a fi salvate.
- **Antete de securitate pe toate paginile:** Content-Security-Policy, HSTS cu preload și blocarea încadrării în alte site-uri (clickjacking).
- **Limitarea încercărilor** la autentificare, împotriva atacurilor de ghicire a parolei.
- **Jurnal de audit** pentru acțiunile importante: cine, ce și când.

- **Ștergere GDPR automată:** o sarcină zilnică urmărește termenele de păstrare a datelor personale.
- **Verificări automate la fiecare modificare:** verificare de tipuri, analiză statică, teste și scanare a dependențelor pentru vulnerabilități cunoscute.
- **Audit intern de securitate** realizat în octombrie 2026, cu plan de remediere în curs.

6. Comparație: cloud actual vs. server intern

Criteriu	Cloud actual (Vercel + Supabase)	Server intern securizat
Certificări auditate	SOC 2 Type 2, ISO 27001, DPA GDPR, deja obținute	Trebuie obținute și auditate de aeroport, cu cost și durată mare
Protecție DDoS / WAF	Inclusă, la scară globală	Echipamente sau servicii separate; limitată de conexiunea internet a aeroportului
Actualizări de securitate	Aplicate continuu de furnizor	Responsabilitatea echipei IT interne, inclusiv noaptea și în weekend
Copii de siguranță	Zilnice, automate, în altă locație	Trebuie proiectate, testate și păstrate în altă locație
Disponibilitate	Infrastructură redundantă, fără punct unic de cădere	Dependentă de un singur centru de date, de alimentare și de conexiune
Control fizic asupra datelor	Indirect, prin contract și certificări	Complet, în spațiile aeroportului
Izolare de rețeaua operațională	Complet separată de sistemele aeroportului	Server public în rețeaua aeroportului, care trebuie izolat (DMZ)
Cost	Abonament lunar previzibil	Hardware, licențe, curent, personal, audit
Timp de implementare	Zero, funcționează deja	Săptămâni sau luni, plus migrarea datelor
Modificări și dezvoltare	Publicare automată la fiecare modificare aprobată	Posibilă, dar necesită configurare și acces securizat la server

7. Avantaje și dezavantaje

Rămânerea pe cloud: avantaje

- Nivel de securitate certificat și auditat anual de terți independenți, greu de egalat intern.
- Separare completă de rețeaua aeroportului: un atac asupra platformei nu poate ajunge la sistemele operaționale sau de siguranță ale aeroportului.
- Protecție automată la atacuri DDoS, fără investiții în echipamente.
- Copii de siguranță și recuperare după dezastru incluse.
- Cost previzibil, fără investiție inițială și fără personal dedicat 24/7.
- Dezvoltarea continuă rămâne rapidă: modificările verificate ajung automat în producție.
- Scalare automată la vârfuri de trafic, de exemplu în campaniile de strângere de fonduri.

Rămânerea pe cloud: dezavantaje și cum se atenuează

- **Furnizori cu sediul în SUA** (legea americană CLOUD Act). Atenuare: date stocate în regiuni UE, DPA semnat, certificare EU-U.S. Data Privacy Framework, criptarea câmpurilor sensibile în aplicație.
- **Dependența de furnizor.** Atenuare: tehnologii standard (PostgreSQL, Next.js), un plan de ieșire documentat și o copie zilnică a datelor la aeroport.
- **Control fizic indirect.** Atenuare: rapoarte SOC 2 și certificate ISO disponibile pentru verificare, plus jurnale de acces.
- **Costurile cresc odată cu volumul.** Atenuare: monitorizarea consumului și praguri de alertă.

Server intern: avantaje

- Control fizic și juridic complet asupra datelor.
- Integrare directă cu politicile și sistemele IT interne ale aeroportului.
- Fără dependență de furnizori externi de găzduire.

Server intern: dezavantaje

- Toată responsabilitatea pentru securitate, actualizări, monitorizare și incidente revine aeroportului.
- Un server accesibil public din rețeaua aeroportului adaugă o suprafață de atac într-o infrastructură critică.
- Investiție inițială (hardware, licențe, firewall, protecție DDoS) și personal specializat permanent.
- Certificările de securitate trebuie obținute separat.
- Migrare cu risc: baza de date, conturile de utilizator, fișierele, webhook-urile de plată și domeniul trebuie mutate fără pierderi.
- Disponibilitate mai mică în caz de pană de curent, de internet sau de hardware.

8. Propunere de compromis

Pentru a îmbina siguranța cloud-ului cu controlul cerut de aeroport, propunem:

1. Platforma rămâne pe Vercel și Supabase, cu toate datele în regiuni din UE.
2. Se semnează DPA-urile cu Vercel și Supabase, iar aeroportul primește rapoartele de conformitate (SOC 2, ISO 27001).
3. Se activează autentificarea în doi pași pentru toate conturile administrative și restaurarea la un moment din trecut (Point-in-Time Recovery).
4. O copie de siguranță criptată a bazei de date se transferă zilnic, automat, pe un server intern al aeroportului.
5. Se documentează un plan de ieșire testat: dacă va fi nevoie, platforma poate fi mutată pe serverul aeroportului în câteva zile, pornind de la acea copie.

Concluzie

Infrastructura actuală oferă un nivel de securitate certificat, pe care un server intern l-ar atinge doar cu investiții și personal semnificative.

Propunerea de compromis dă aeroportului controlul asupra datelor, prin copia zilnică și planul de ieșire, fără riscurile operării unui server public în rețeaua sa.